

CENTRALIZED ENTERPRISE MULTI-FACTOR AUTHENTICATION (MFA) MICROSERVICE

Final Software Engineering Capstone Report

Course: Software Engineering Capstone

Author: Jack McCoy

Date: August 23, 2026

Repository: <https://github.com/jackmccoy/enterprise-mfa-service>

Demonstration: <https://youtu.be/S14jyJHOPoA>

1. Executive Summary & System Purpose

The Centralized Enterprise Multi-Factor Authentication (MFA) Microservice is a high-throughput, security-focused authentication engine designed to provide plug-and-play two-factor authentication (2FA) for modern web and mobile applications. By decoupling identity verification from core business logic, this service allows organizations to enforce strict secondary authentication without altering primary application databases. Standard single-factor authentication is highly vulnerable to credential stuffing and phishing; this system addresses those risks through a unified, scalable microservice.

Key Technical Highlights:

- Full compliance with standard Time-based One-Time Password (TOTP) specifications (RFC 6238).
- Intermediate state isolation utilizing short-lived `pre_auth_token` sessions.

- Emergency single-use recovery code generation and hashed storage using Argon2id or BCrypt.
- Session-scoped rate limiting to mitigate Account Lockout Denial-of-Service (DoS) attacks.

2. Target Audience & Core Features

Target Users

- **End-Users:** Individuals enrolling in 2FA via QR code scanning and providing secondary codes during login.
- **Integrating Developers:** API consumers utilizing RESTful endpoints to validate secondary credentials.
- **System Administrators:** Security personnel managing account recovery overrides and monitoring audit logs.

Core Feature Specifications

- **Feature 1: Secondary Auth Handshake:** Validates primary credentials and issues a temporary 5-minute `pre_auth_token` restricted strictly to MFA verification routes.
- **Feature 2: TOTP Engine & QR Provisioning:** Generates cryptographically secure 160-bit secret keys and exports standard `otpauth://` QR codes for application scanning.
- **Feature 3: Emergency Recovery Engine:** Generates 10 single-use 8-character backup codes, stored as secure hashes to prevent exposure during breaches.
- **Feature 4: Adaptive Rate-Limiting:** Tracks verification velocity to prevent brute-force attacks while protecting against intentional attacker-induced lockouts.

3. Technology Stack & Architecture

Tech Stack Specifications

- **Language/Framework:** Node.js (TypeScript) / Express.js
- **Cryptography:** otplib (RFC 6238), bcrypt, and AES-256-GCM for secrets at rest.
- **Token Management:** JSON Web Tokens (JWT) for short-lived session handling.
- **Persistence:** PostgreSQL (Production ready) with encrypted storage.

- **Testing:** Jest, Supertest, and Postman for automated verification.

System Architecture

The system utilizes a microservice architecture where the API Gateway handles rate limiting and token validation before passing requests to the MFA Engine. All stored TOTP secrets are encrypted at rest using envelope encryption via a Key Management Service (KMS).

4. Comprehensive Testing Report

A. Test Execution Summary

Category	Total Tests	Passed	Coverage
Unit Tests	18	18	92% (TOTP & Crypto)
Integration Tests	12	12	88% (API & DB)
Security Cases	8	8	100% (Lockouts)
Performance	2	2	500 Req/Sec @ 120ms P95

B. Detailed Test Suite Matrix

Test ID	Category	Description & Input	Expected Result	Status
TC-01	Unit ▾	Secret Key + System Time	Valid 6-digit TOTP code	PASS ▾
TC-02	Unit ▾	Code generated 25s prior	Validated (±1 step tolerance)	PASS ▾

Test ID	Category	Description & Input	Expected Result	Status
TC-03	Integrati... ▾	Valid primary credentials	Return 200 & <code>pre_auth_token</code>	PASS ▾
TC-04	Security ▾	Token > 5 minutes old	401 Unauthorized	PASS ▾
TC-05	Security ▾	5 consecutive bad codes	Session Lockout / 429 Error	PASS ▾

5. Challenges Faced & Lessons Learned

- 1. **State Isolation:** Ensuring the initial authentication phase never leaks full session rights. Resolved by enforcing strict `pre_auth_token` verification on secondary endpoints.
- 2. **Account Lockout DoS:** Balancing security against abuse by shifting rate limiting from global accounts to individual session tokens, preventing malicious actors from locking out legitimate users.
- 3. **Clock Drift Management:** Resolved time skew issues between devices and servers by implementing a standard ± 1 step window (30 seconds) during TOTP verification.

6. Glossary of Terms

Term	Definition
TOTP	Time-based One-Time Password algorithm (RFC 6238).
Pre-Auth Token	A temporary JWT issued after primary check, restricted to MFA routes.

Term	Definition
Envelope Encryption	Encrypting data with a local key, which is then encrypted by a Master Key.
Brute-Force Protection	Mechanisms to prevent automated guessing by limiting request velocity.